PENSE-BÊTE · CONCEPTS RÉSEAU ET ARCHITECTURE

Supervision WAN et Conformité NIS2

09-610 Supervision Réseau WAN et Conformité NIS2 — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'extension TimescaleDB optimise le stockage via des hypertables : chunk_time_interval est dimensionné pour qu'un bloc non compressé occupe 1/4 de la RAM.
2. Le choix optimal de supervision repose sur le couple Zabbix et TimescaleDB pour sa haute disponibilité et son intégration modérée.
3. La conformité NIS2 impose l'usage exclusif de SNMPv3 avec le niveau de sécurité AuthPriv pour garantir le chiffrement et l'authentification.

Étude de faisabilité et dimensionnement

Notion	À retenir
Architecture et split-brain	Cluster **PostgreSQL/Patroni** sur **2 serveurs** : risque de **split-brain**. Utiliser un **QDevice/Witness** (via **etcd**) pour assurer le **quorum** (majorité absolue via **Raft**).
Métrologie NQA	Sondes **NQA** (**Comware**) via **SNMP** (**HH3C-NQA-MIB**) : **12000** métriques/min (**200** val/s) pour **600** routeurs. Mesure : latence, gigue, perte, erreurs.
Stockage et agrégation	Extension **TimescaleDB** (**hypertables**) : **chunk_time_interval** dimensionné pour qu'un bloc non compressé occupe **1/4** de la RAM. **Continuous Aggregates** (vues pré-calculées) et purge via `drop_chunks`.
Green IT et ressources	Optimisation **PUE** par densification sur **2 hyperviseurs** et **C-states**. Bases : **8 vCPU**, **32 Go** RAM, **250 Go** NVMe. Témoin : **1 vCPU**, **1 Go** RAM, **10 Go** disque.

Comparatif des solutions de supervision

Notion	À retenir
Pile sur-mesure	Agent léger `Telegraf` (**Go**) + `PostgreSQL` + `TimescaleDB` + `Grafana`. Effort d'intégration **très élevé** : configuration manuelle des identifiants **Comware**.
Zabbix + TimescaleDB	Solution intégrée avec **LLD** (découverte automatique **Comware**), moteur d'alerte **SLA** et haute disponibilité native.
LibreNMS	Spécialisé réseau (**LLDP**, routage, sondes **NQA**). Architecture **MySQL/MariaDB** moins performante que **TimescaleDB**. HA complexe (**Galera**, **Memcached**, **Redis**).
HPE IMC	Propriétaire, intégration parfaite (**NQA**, firmware). Architecture **Java** gourmande (contraire **Green IT**). Coût élevé (**licences au nœud**).
Synthèse et choix	Open-source = coût licence **nul**. Choix optimal : **Zabbix + TimescaleDB** (intégration modérée, HA excellente, **TCO maîtrisé**).

Paramètres de dimensionnement et ressources

6 milliards
points de données bruts annuels

4 vCPU / 8 Go / 50 Go
allocation nœuds de collecte et présentation

1 vCPU / 1 Go / 10 Go
allocation nœud témoin (QDevice)

Stratégies de maintien et support

Notion	À retenir
Support éditeur direct	Évite le **Shadow IT**. **EnterpriseDB** (PostgreSQL, TimescaleDB, Patroni) : support **24h/24**, intervention **15 à 30 min**. **Zabbix SIA** : souscriptions **Gold**, **Platinum** et **Enterprise**.
TMA via ESN	Offre un **guichet unique** pour la chaîne d'acquisition. Gère les bugs entre **Comware** et graphiques. **Pas d'accès au code source** du noyau (dépendance correctifs communautaires).
Gouvernance Back-to-Back	Modèle hybride : **ESN locale** (niveaux **1 et 2**, exploitation, sondes **NQA**, tableaux de bord en **heures ouvrées**) + **éditeurs** (niveau **3**, escalade défaillance cœur logiciel).

Conformité NIS2 et ReCyF

Notion	À retenir
Sécurisation métrologie	Interdiction **SNMPv1/v2c** (clair). Utilisation exclusive de **SNMPv3** avec niveau **authPriv** (**HMAC-SHA-256** et **AES-256**).
Contrôle accès (ReCyF)	Objectif **11** : gestion identités. Rôles restreints aux périmètres des **250 agents**. Authentification **MFA** via **SAML** ou **OpenID Connect**.
Chaîne d'approvisionnement	Nomenclatures **SBOM** (**Syft** ou **CycloneDX**). Inventaire cryptographique. Patchs via **registre interne audité** (pas d'accès direct Internet).
Journalisation et incidents	Logs vers **SIEM** en temps réel. Alerte **ANSSI** sous **24 heures** (intrusion majeure). Rapport détaillé sous **72 heures**, rapport final sous **un mois**.

Mesures de sécurité et administration

- **Plan de contrôle** : protégé par ACL rejetant tout trafic SNMP non issu de l'**IP virtuelle**.
- **Administration système** : doit transiter par un **réseau dédié** avec **bastion PAM**.
- **Bastion PAM** : assure la **rotation automatique des secrets** et l'**enregistrement probatoire** des sessions.
- **Détection d'attaque** : analyse des **variations anormales de charge processeur** (indicateur de déni de service).
- **Gestion des correctifs** : les serveurs de supervision téléchargent les patchs sur un **registre interne audité**.

Pièges et confusions

⚠ Croire qu'un quorum Raft peut être obtenu sur deux nœuds physiques sans ajouter un QDevice.
⚠ Utiliser les versions SNMPv1 ou SNMPv2c qui sont proscrites par le Référentiel Cyber France.
⚠ Effectuer une administration système en accès direct depuis le réseau bureautique au lieu de passer par un bastion PAM.
⚠ Oublier que le délai de notification d'une intrusion majeure à l'ANSSI est de 24 heures.
⚠ Sous-estimer l'impact de sondes NQA mal configurées qui peuvent saturer le processus nqad des routeurs.

Sigles et définitions

ANSSI Agence Nationale de la Sécurité des Systèmes d'Information en charge de la cyberdéfense française.
AuthPriv Niveau de sécurité SNMPv3 combinant l'authentification forte et le chiffrement du trafic.
QDevice Nœud témoin externe participant uniquement aux votes de consensus sans stocker de données.
PAM Solution de Gestion des Accès à Privilèges contrôlant et enregistrant les sessions d'administration.
NIS2 Directive européenne établissant un niveau élevé commun de cybersécurité à l'échelle de l'Union.
NQA Module Network Quality Analyzer intégré à Comware pour mesurer la latence, la gigue et les pertes.

Auto-test

1. Quel algorithme est utilisé par Patroni pour piloter le consensus ?
2. Quelle fonction de TimescaleDB permet la purge automatisée des données ?
3. Quel est le délai pour envoyer un rapport détaillé après une intrusion ?
4. Quelle plateforme propriétaire de HPE est jugée gourmande et contraire au Green IT ?
5. Comment appelle-t-on la stratégie de support combinant une ESN locale et les contrats éditeurs ?

Réponses : **1.** Raft · **2.** Drop_chunks · **3.** 72 heures · **4.** HPE IMC · **5.** Back-to-Back

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.